

Investigation of Unauthorized Transactions Caused by Compromised Fintech Customer Accounts

Track: Incident Investigation

Target Organization: NuePay (fictional mobile P2P payment fintech)

Prepared by: Abigail Kwablah

Date: September 20, 2026

1. Executive Summary

NuePay, a fictional mobile peer-to-peer payment company, experienced a phishing-driven account takeover in which three customers received a fraudulent SMS message and submitted their login credentials on a fake page. The attacker used the stolen credentials, without the customers' one-time password, to log into all three accounts and transfer a combined GHS 13,950.00 to a single external account within minutes of each login. The investigation traced the full attack path from the phishing message to the fraudulent transfers using authentication and transaction logs, and found that one-time password verification, while available, was not enforced on every login path. The incident affected three of NuePay's approximately 1,200 active customers, with no evidence of broader compromise or service disruption.

2. Background and Scope

NuePay is a fictional mobile P2P payment fintech serving approximately 1,200 active customers. This investigation covers a single phishing campaign on 2026-08-20 in which three customer accounts were compromised and used to make unauthorized transfers. In scope: the three affected accounts, the authentication and transaction logs tied to the incident, and the security controls directly relevant to how the compromise occurred. Out of scope: NuePay's broader infrastructure, unrelated customers, and any redesign of NuePay's overall security architecture.

3. Incident Timeline

All times UTC, 2026-08-20.

Time	Event	Detail
08:51:02	Failed login attempt, CUST-0231	Attacker mistypes stolen password on first attempt
08:52:14	Suspicious login, CUST-0231	45.155.205.12 / DEV-ATK0001 (Amsterdam), password only, new device + new location
08:54:02	Unauthorized transaction, CUST-0231	GHS 4,800.00 to NUE-MULE0099, 1m48s after login
11:07:39	Suspicious login, CUST-0587	Same IP/device, password only, new device + new location
11:09:15	Unauthorized transaction, CUST-0587	GHS 3,950.00 to NUE-MULE0099, 1m36s after login
13:41:56	Suspicious login, CUST-0942	Same IP/device, password only, new device + new location
13:44:30	Unauthorized transaction, CUST-0942	GHS 5,200.00 to NUE-MULE0099, 2m34s after login

The precursor phishing message that led to credential disclosure corresponds to MITRE ATT&CK T1566 (Phishing). Gaining account access using the resulting stolen, but legitimate, credentials corresponds to MITRE ATT&CK T1078 (Valid Accounts).

Externally-driven determination: the source IP (45.155.205.12) and device ID (DEV-ATK0001) do not appear in any baseline activity for any customer in the evidence set, resolve to Amsterdam while all three victims' accounts are based in Ghana, and accessed three otherwise-unconnected accounts within a five-hour window. This pattern is consistent with externally-controlled attack infrastructure, not insider activity.

4. Root Cause

Authentication succeeded using a password alone on all three attacker logins (auth_method = password), while every other login on record for these same three customers used password+otp. Because password-only authentication was accepted, the credential stolen via phishing was sufficient on its own to gain full account access; possession of the customer's OTP device was not required.

Root cause: OTP/2FA was not enforced on every login path, despite being NuePay's normal second factor.
Contributing factor: each attacker login was flagged by the system itself (`is_new_device = true`, `is_new_location = true`), but this anomaly signal was not used to block or challenge the session.

5. Impact

Confidentiality: Impacted. Customer credentials and account data were exposed to the attacker once access was gained.

Integrity: Impacted. Transaction records for all three accounts were altered by the unauthorized transfers.

Availability: Not impacted. No evidence of service outage or denial of access; unaffected customers transacted normally throughout.

Financial impact: GHS 13,950.00 across three accounts (GHS 4,800.00 + GHS 3,950.00 + GHS 5,200.00), all to one external recipient. Scope is limited to these three of NuePay's approximately 1,200 active customers; no evidence supports broader compromise.

6. Response Actions Taken

- Contain the accounts: block CUST-0231, CUST-0587, and CUST-0942 from further withdrawals or transfers.
- Trace and flag the destination: trace the transferred funds to NUE-MULE0099 and flag or freeze that account where technically possible.
- Verify the message source internally: confirm the phishing SMS did not originate from NuePay's own messaging systems.
- Reset credentials: force a password reset and require OTP re-enrollment for all three accounts before restoring access.
- Review account activity: check the three accounts for further unauthorized activity and confirm no other accounts show the same IP/device pattern.
- Restore safe access: unblock the accounts once credentials are reset and OTP re-enrolled.

7. AI Integration

An AI chat assistant was used to analyze `authentication_logs.csv` and identify suspicious login activity. Given only the raw authentication log, the tool correctly flagged the three attacker logins as the primary anomaly, correctly identified the password-only vs. password+otp distinction as the key signal, and correctly avoided flagging two unrelated failed-then-successful login pairs as malicious, recognizing them as ordinary retries on the same device, IP, and location.

The tool's output was independently verified against the transaction log and found accurate but incomplete: it could not, from authentication data alone, correlate the logins to the corresponding fraudulent transactions, the shared recipient account, or the MITRE ATT&CK mapping. That cross-file correlation and framework mapping was performed through human analysis. See Evidence section for a screenshot of this session.

8. Recommendations

1. Enforce OTP on every login path (MITRE M1032)

Require OTP verification on all account logins, with no path that accepts a password alone. This directly closes the gap identified in the Root Cause section: all three attacker logins used password only, while every legitimate login used password+otp.

2. Act automatically on device/location anomaly flags (MITRE M1036)

Configure the system to automatically require step-up verification or block a session when is_new_device and is_new_location both fire, rather than only logging the anomaly after the fact.

3. Customer phishing awareness messaging (MITRE M1017)

Send customers a standing, verified-channel notice that NuePay will never request account verification via SMS link, with a clear way to report suspicious messages. This does not address this incident's root cause directly but reduces the likelihood of future customers falling for similar campaigns.

9. Evidence

Screenshot 1: AI-assisted anomaly detection

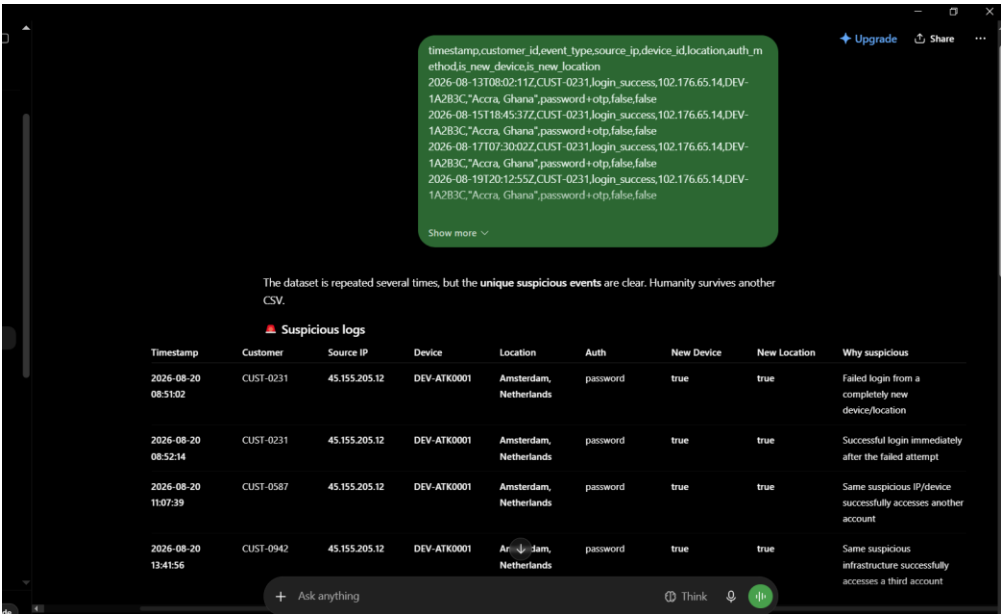


Figure 1. AI chat session identifying suspicious logins from authentication_logs.csv, supporting the AI Integration section.

Screenshot 2: Login-to-transaction correlation

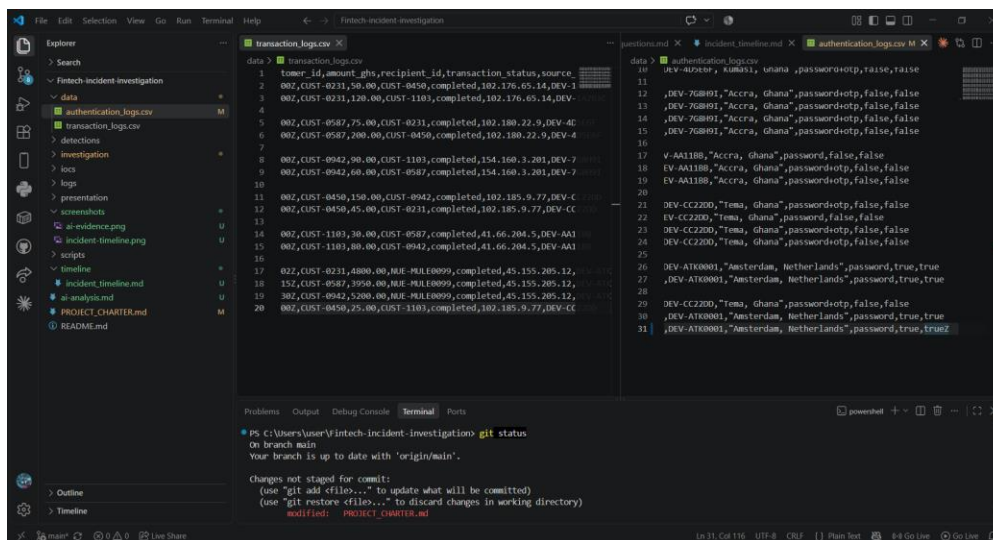


Figure 2. Correlation between attacker login sessions and the corresponding unauthorized transactions, supporting the Incident Timeline and Root Cause sections.

Screenshot 3: Investigation timeline

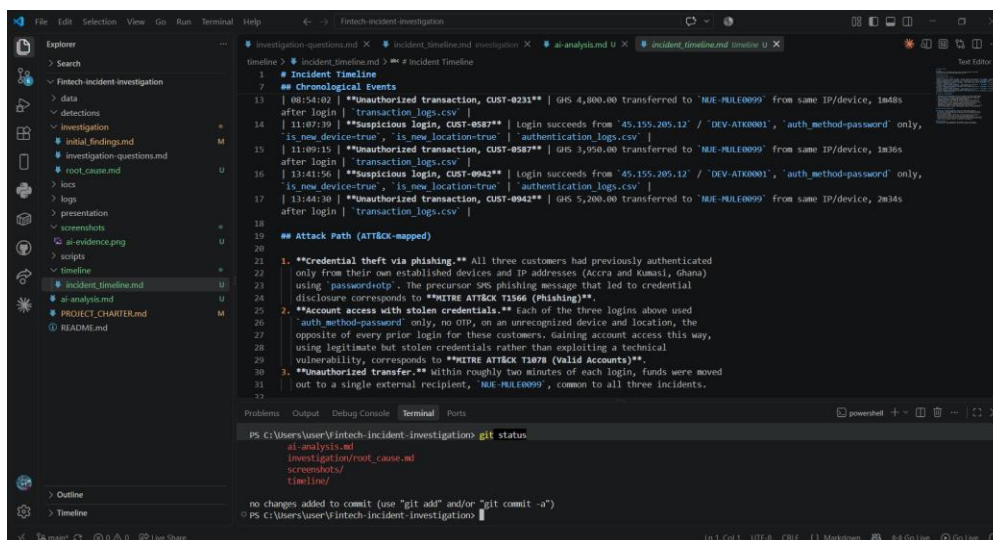


Figure 3. Investigation view of the chronological incident timeline, supporting the Incident Timeline section.

Diagram: Incident flow

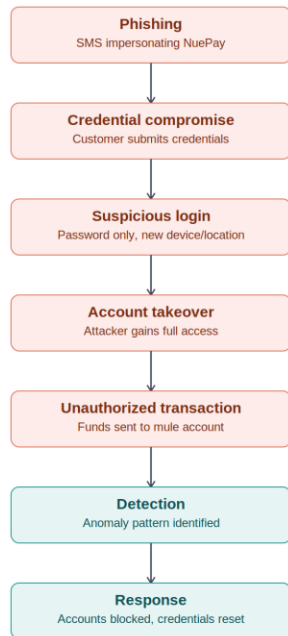


Figure 4. End-to-end incident flow diagram, phishing through response.

10. Reflection

This project relied most on log correlation and evidence-based reasoning: connecting authentication anomalies to their corresponding transactions, and tracing a root cause back to specific field values rather than general assumptions. Verifying the AI-assisted analysis against the underlying data, rather than accepting its output directly, was also a key part of the process. If starting again, I would build the anomaly-detection logic and the transaction data at the same time, since correlating the two datasets earlier would have made the timeline and root cause work faster.